

在线论文文档自动生成 系统

详细设计说明书

版本：V1.0

项目名称： 在线论文文档自动生成工具
文档类型： 详细设计说明书
版本号： V1.0
编写日期： 2026 年 7 月 15 日

实训项目组

2026 年 7 月 15 日

目录

1	引言	3
1.1	编写目的	3
1.2	项目背景	3
1.3	定义	3
1.4	参考资料	3
2	任务概述	4
2.1	需求概述	4
2.2	运行环境	4
2.3	条件与限制	4
3	模块详细设计	4
3.1	用户权限控制模块设计	4
3.1.1	模块概述	4
3.1.2	模块输入输出接口	4
3.1.3	模块处理逻辑流程	5
3.1.4	模块内部数据结构	5
3.1.5	模块算法设计	5
3.1.6	模块异常处理逻辑	5
3.2	其他业务模块	6
4	接口详细设计	6
4.1	外部接口详细设计	6
4.1.1	用户交互接口	6
4.1.2	第三方软件接口	6
4.1.3	Hardware 接口	6
4.2	内部模块接口详细设计	6
4.2.1	模块间请求参数定义	6
4.2.2	返回数据结构定义	6
4.2.3	调用时序说明	6
5	数据结构详细设计	6
5.1	全局数据结构说明	6
5.2	数据库表详细设计	6
5.2.1	用户主表 (sys_user)	7
5.2.2	学院基础信息表 (sys_college)	7
5.3	缓存/临时数据结构设计	7
6	算法详细设计	7
6.1	核心算法：全局请求鉴权与 RBAC 隔离算法	7
6.1.1	算法描述	7
6.1.2	输入输出参数	8
6.1.3	代码实现	8
6.1.4	边界条件处理	9

7	界面详细设计	9
7.1	页面输入校验规则	9
8	出错处理详细设计	9
8.1	模块内部异常分类	9
8.2	异常捕获流程	9
8.3	异常返回信息定义	9
9	安全详细设计	9
9.1	身份校验逻辑	9
9.2	数据加密处理设计	9
9.3	防攻击处理逻辑（防水平越权）	10
10	维护详细设计	10
10.1	日志模块设计	10
10.2	配置项设计	10

修订记录

版本号	修订日期	修订人	审核人	修订说明
V1.0	2026-07-13	[您的名字]	全组	完成用户中心、JWT 鉴权、RBAC 权限控制、核心加盐哈希算法及底层数据库物理表详细设计

1 引言

1.1 编写目的

本文档为在线论文文档自动生成工具详细设计说明书。本文档立足于项目负责人及基础架构工程师视角，旨在将概要设计阶段确定的“用户鉴权与角色控制”模块进行具体代码化与物理结构化设计。文档详细定义了核心数据库字段约束与索引、RESTful请求与返回的 JSON 载荷、鉴权过滤算法伪代码及安全防御逻辑，作为后续基础架构编码以及全组合规接入的直接实现蓝本。

1.2 项目背景

本系统为 Web 端在线论文编辑与标准化文档生成系统，由实训开发小组协同开发。基础架构模块作为整个系统的底座，必须优先完成编码交付，确保模板管理、富文本编辑器、文档导出、线上批阅等业务功能模块能基于统一的用户上下文及权限网关进行并行开发。

1.3 定义

- **BCrypt:** 一种基于 Blowfish 加密算法的强哈希密码散列函数，内置随机加盐机制，具备自适应工作因子，能有效防御彩虹表与暴力破解攻击。
- **JWTInterceptor:** 后端控制层拦截器，用于在执行具体控制器逻辑前，对 HTTP 请求头中的 Token 进行提取、验签、解码及权限校验。
- **Security Context:** 系统运行期线程上下文，用于安全地暂存当前通过鉴权的用户实体信息，供同线程内的业务代码随时获取。

1.4 参考资料

1. GB/T 8567-2006 计算机软件文档编制规范——详细设计说明书；
2. 《在线论文文档自动生成工具概要设计说明书》V1.0；
3. RFC 7519: JSON Web Token (JWT) 技术标准规范。

2 任务概述

2.1 需求概述

本系统需建立完善的统一用户中心及基于角色的权限控制体系（RBAC）。系统强制划分三类核心角色：系统管理员负责院系与多类型论文模板管控；学生用户负责选用模板、在线编辑、暂存草稿及导出文档；教师用户拥有课程论文的专属批阅、添加批注、评定成绩与退回权限。基础架构必须在技术底座上实现无状态鉴权与全方位的越权拦截。

2.2 运行环境

- 客户端环境：支持主流现代化 Web 浏览器（Chrome, Edge, Safari, Firefox 等）；
- 服务端环境：Linux/Ubuntu 22.04 LTS, Java 17或 Python 3.10 运行环境；
- 数据库环境：MySQL 8.0关系型数据库，Redis 7.0 缓存服务器。

2.3 条件与限制

由于本系统属于高校软件工程实训项目，开发周期紧凑。基础架构人员（人员 1）必须比其他业务模块开发人员提早 3-5 天完成统一接口规范定义、无状态拦截器骨架搭建以及底层数据库表物理建表，否则将直接阻塞后续富文本编辑与批阅模块的串联开发。

3 模块详细设计

3.1 用户权限控制模块设计

3.1.1 模块概述

本模块是系统的核心安全中枢，承担全站用户的注册登录、身份凭证分发（JWT 签发）、无状态请求拦截验签、以及基于 RBAC 模型的管理员（ADMIN）、学生（STUDENT）、教师（TEACHER）三类角色的权限阻断与放行。本模块为全站提供统一的、基于线程绑定的用户上下文（UserContext）。

3.1.2 模块输入输出接口

本模块面向前端提供统一的 RESTful 标准 JSON 接口，以登录验证接口为例：

1. 用户登录认证接口：

- 请求 URL: POST /api/auth/login
- 请求 Payload (JSON):

```
{  "username": "202611001",  "password": "mypassword123",  "role": "STUDENT"}
```
- 返回 Data (JSON):

```
{
  "code": 200,
  "message": "Login Success",
  "data": {
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
    "expireTime": 1783932400,
    "userId": 10021,
    "realName": "张同学"
  }
}
```

3.1.3 模块处理逻辑流程

用户访问系统时，基础架构鉴权拦截器的处理逻辑流程如下：1. 前端发送请求 → 2. 拦截器判断是否为免鉴权白名单（如 `/api/auth/login`）→ 3. 若是则直接放行；若否则从请求头提取 `Authorization` → 4. 解析并验证 JWT 签名与失效时间 → 5. 解析对应角色，匹配当前路由访问权限 → 6. 成功后写入运行期线程上下文（Security Context）并放行至后续业务控制器。

3.1.4 模块内部数据结构

后端运行期内存中维护的用户上下文实体（供全组随取随用）结构定义如下：

```
@dataclasses.dataclass
class UserContextEntity:
    user_id: int          # 用户唯一物理ID
    username: str         # 登录账号(学号/工号)
    role_code: str        # 角色编码: ADMIN / STUDENT / TEACHER
    college_id: int       # 所属学院ID
    client_ip: str        # 客户端请求IP
```

3.1.5 模块算法设计

模块核心的“全局请求鉴权过滤算法”在后文“第 6 节算法详细设计”中统一展开实现。

3.1.6 模块异常处理逻辑

- 当请求未携带 Token、Token 格式错误或验签失败时，抛出 `UnauthenticatedException` 运行时异常，拦截器直接就地阻断。
- 当解析的角色与当前请求的路由权限边界不匹配（如学生企图调用管理员接口），抛出 `UnauthorizedException` 终止业务流转。

3.2 其他业务模块

4 接口详细设计

4.1 外部接口详细设计

4.1.1 用户交互接口

采用基于 HTTP/1.1 的纯 Web 可视化人机交互界面，页面输入参数通过 JSON 异步传输。

4.1.2 第三方软件接口

数据库交互采用 MySQL 标准数据库驱动连接接口；系统内部缓存高频 Token 黑名单采用标准 Redis 客户端连接。

4.1.3 Hardware 接口

无专用硬件外设接口，依赖标准网络协议（TCP/IP）。

4.2 内部模块接口详细设计

4.2.1 模块间请求参数定义

所有受保护的接口（如模板创建、草稿保存、论文批阅），前端在发起 HTTP 请求时，必须在 Header 中强制注入：Authorization: Bearer <Token_String>。

4.2.2 返回数据结构定义

基础架构规范了全组统一的公共返回对象封装结构：

```
@dataclasses.dataclass
class Result:
    code: int          # 状态码：200-成功，401-未认证，403-无权限，500-系统异常
    message: str       # 响应文本提示信息
    data: any          # 具体业务逻辑返回的JSON数据载荷
```

4.2.3 调用时序说明

调用链由基础架构网关/拦截器优先触发，验签成功并解出 UserContextEntity 后，生命周期才移交给具体的业务子模块（如人员 4 的论文草稿保存逻辑）。

5 数据结构详细设计

5.1 全局数据结构说明

系统在运行期通过 ThreadLocal 绑定当前请求线程的 UserContextEntity，实现全流程用户身份的无感知传递。

5.2 数据库表详细设计

采用 MySQL 8.0 关系型数据库，由基础架构统一设计并建立以下系统核心底座表：

5.2.1 用户主表 (sys_user)

存储系统所有管理员、教师、学生账号的安全凭证及属性。

字段名	数据类型	可空	默认值	说明与约束
id	bigint	NO	自增	无符号主键 ID
username	varchar(32)	NO	无	UNIQUE, 登录账号 (学号/工号)
password_hash	varchar(128)	NO	无	BCrypt 强哈希加密后的密文
real_name	varchar(32)	NO	无	用户真实姓名
college_id	bigint	NO	无	逻辑外键, 关联 sys_college.id
role_code	varchar(20)	NO	无	角色属性: ADMIN / STUDENT / TEACHER
status	tinyint	NO	1	账户状态: 1-启用, 0-禁用
create_time	datetime	NO	CURRENT	记录创建时间

表 2: sys_user 表物理结构定义

索引设计:

- PRIMARY KEY (id): 聚集索引;
- UNIQUE INDEX uk_username (username): 保障全站账号唯一, 极大提升登录时单条记录的检索速度;
- INDEX idx_college_role (college_id, role_code): 复合非聚集索引, 便于管理员后续高效地分学院、分身份批量管理用户。

5.2.2 学院基础信息表 (sys_college)

供管理员分类绑定论文格式模板 (对应人员 2 模块)。

字段名	数据类型	可空	默认值	说明与约束
id	bigint	NO	自增	学院主键 ID
college_name	varchar(64)	NO	无	UNIQUE, 院系官方全称
create_time	datetime	NO	CURRENT	记录创建时间

表 3: sys_college 表物理结构定义

5.3 缓存/临时数据结构设计

采用 Redis 暂存主动登出或强制下线的未过期 Token 黑名单, 数据类型为 String。Key 结构设计为 auth:blacklist:token:{md5(Token)}, 其 TTL 自动设置为 Token 的剩余有效秒数, 拦截器拦截到黑名单内 Token 则直接判为失效。

6 算法详细设计

6.1 核心算法: 全局请求鉴权与 RBAC 隔离算法

6.1.1 算法描述

拦截器对进入系统的 HTTP 请求执行动态路由拆包、合法性验签、时效性检查, 并严格依据路由前缀实施多角色垂直越权拦截, 成功后将用户实体封装挂载至线程上下文。

6.1.2 输入输出参数

- 输入: request (HTTP 请求封装对象), 包含请求头及 RequestURI。
- 输出: boolean (True 表示允许放行进入核心业务层, False 拒绝)。

6.1.3 代码实现

```
def pre_handle_intercept(request, response) -> bool:
    # 1. 路由白名单直接放行(如登录接口)
    uri = request.get_request_uri()
    if uri.startswith("/api/auth/"):
        return True

    # 2. 从HTTP Header中安全提取Token凭证
    auth_header = request.get_header("Authorization")
    if not auth_header or not auth_header.startswith("Bearer "):
        raise UnauthenticatedException("Missing identity credentials.")
    token = auth_header.substring(7)

    # 3. 解析并校验JWT合法性与时效
    payload = jwt_provider.validate_and_parse(token)
    if payload is None or payload.is_expired():
        raise UnauthenticatedException("Token has expired or is invalid.")

    # 4. 基于业务路由前缀执行严格的RBAC垂直越权拦截
    user_role = payload.role_code
    if uri.startswith("/api/admin/") and user_role != "ADMIN":
        raise UnauthorizedException("Admin operations restricted.")
    if uri.startswith("/api/student/") and user_role != "STUDENT":
        raise UnauthorizedException("Student operations restricted.")
    if uri.startswith("/api/teacher/") and user_role != "TEACHER":
        raise UnauthorizedException("Teacher operations restricted.")

    # 5. 组装全局线程上下文, 供同小组其他功能模块并行开发时一键获取当前操作人
    context_user = UserContextEntity(
        user_id=payload.user_id,
        username=payload.username,
        role_code=user_role,
        college_id=payload.college_id,
        client_ip=request.get_remote_ip()
    )
    SecurityContextHolder.set_context(context_user)
    return True
```

6.1.4 边界条件处理

若高频客户端在极短时间内发起并发请求，且遭遇 Token 刚好过期的交界点，系统设计了双 Token 续期机制（Refresh Token），在边界状态下允许前端静默刷新，提升学生在线撰写论文时的用户体验。

7 界面详细设计

7.1 页面输入校验规则

基础架构在登录界面层制定了刚性的前置校验规则：账号长度限制在 5-32 位，密码长度限制在 6-20 位。输入包含特殊 SQL 注入关键字（如 `select`, `drop`, `--`）时，前端框架将直接阻断提交。

8 出错处理详细设计

8.1 模块内部异常分类

包含 `UnauthenticatedException`（401 未登录认证）与 `UnauthorizedException`（403 无对应角色权限/越权访问）。

8.2 异常捕获流程

任何业务层抛出的安全异常，均向上抛出并最终由基础架构的全局异常处理器（Global Exception Handler）切面统一捕获。

8.3 异常返回信息定义

触发越权攻击时，系统统一熔断并返回：

```
{
  "code": 403,
  "message": "Access Denied: Illegal privilege escalation detected.",
  "data": null
}
```

9 安全详细设计

9.1 身份校验逻辑

全面实行基于 JWT 的无状态感知转换，密钥密存。

9.2 数据加密处理设计

用户密码全部采用 BCrypt 哈希算法加盐存储，严禁明文暴露。

9.3 防攻击处理逻辑（防水平越权）

为了防范水平越权（如学生 A 修改学生 B 的论文），基础架构强制约束后续论文编辑模块的代码逻辑必须按如下规则设计：

```
# 基础架构硬性约束的防水平越权代码范式
current_uid = SecurityContextHolder.get_context().user_id
current_paper = paper_repository.query_by_id(request.get_paper_id())
if current_paper.creator_id != current_uid:
    raise UnauthorizedException("Horizontal privilege escalation: Permission denied.")
```

10 维护详细设计

10.1 日志模块设计

设计全局统一的 AOP 日志切面。凡是触发用户登录、管理员发布/下架模板、学生提交论文、教师评定分数等高危、核心动作，基础架构自动拦截并异步输出审计日志至 `sys_operation.log`。

10.2 配置项设计

包含 JWT 过期时间（默认 2 小时）、数据库物理连接池上限等核心参数，统一通过外部配置文件维护。